

# Laboratorio DVWA e Burp Suite

Corso: CyberSecurity

Studente: Martina Foresta

Esercizio: Installazione DVWA e analisi di una richiesta HTTP

Traccia: predisporre nella macchina virtuale Kali Linux l'applicazione Damn Vulnerable Web Application, configurare i servizi necessari e usare Burp Suite per osservare e verificare in modo controllato una richiesta di login.

Dopo essere entrata come amministratore con `sudo su`, mi sono spostata nella cartella `/var/www/html`. Ho clonato il progetto DVWA dal repository ufficiale, ho assegnato i permessi alla cartella e ho creato il file di configurazione partendo dal modello disponibile.

```
Session Actions Edit View Help
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
# cd /var/www/html

(root@kali)-[/var/www/html]
# git clone https://github.com/digininja/DVWA
Cloning into 'DVWA' ...
remote: Enumerating objects: 5800, done.
remote: Counting objects: 100% (20/20), done.
remote: Compressing objects: 100% (11/11), done.
remote: Total 5800 (delta 12), reused 9 (delta 9), pack-reused 5780 (from 3)
Receiving objects: 100% (5800/5800), 2.94 MiB | 9.84 MiB/s, done.
Resolving deltas: 100% (2873/2873), done.

(root@kali)-[/var/www/html]
# chmod -R 777 DVWA/

(root@kali)-[/var/www/html]
# cd DVWA/config

(root@kali)-[/var/www/html/DVWA/config]
# cp config.inc.php.dist config.inc.php

(root@kali)-[/var/www/html/DVWA/config]
# nano config.inc.php

(root@kali)-[/var/www/html/DVWA/config]
#
```

Il comando git clone ha scaricato il progetto nella directory DVWA. Il file config.inc.php.dist è stato poi copiato in config.inc.php, il file che contiene le impostazioni dell'applicazione.

Nel file /var/www/html/DVWA/config/config.inc.php ho impostato la connessione al database locale. Ho usato il server 127.0.0.1, il database dvwa, la porta 3306 e l'utente di laboratorio kali.



```
root@kali: /var/www/html/DVWA/config
Session Actions Edit View Help
GNU nano 9.2 config.inc.php *
<?php
# If you are having problems connecting to the MySQL database and all of the variables below are correct
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to sockets.
# Thanks to @digininja for the fix.

# Database management system to use
$DBMS = getenv('DBMS') ?: 'MySQL';
#$DBMS = 'PGSQL'; // Currently disabled

# Database variables
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED during setup.
# Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user.
# See README.md for more information on this.
$_DVWA = array();
$_DVWA['db_server'] = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA['db_database'] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA['db_user'] = getenv('DB_USER') ?: 'kali';
$_DVWA['db_password'] = getenv('DB_PASSWORD') ?: 'kali';
$_DVWA['db_port'] = getenv('DB_PORT') ?: '3306';

# ReCAPTCHA settings
# Used for the 'Insecure CAPTCHA' module
# You'll need to generate your own keys at: https://www.google.com/recaptcha/admin
$_DVWA['recaptcha_public_key'] = getenv('RECAPTCHA_PUBLIC_KEY') ?: '';
$_DVWA['recaptcha_private_key'] = getenv('RECAPTCHA_PRIVATE_KEY') ?: '';

# Default security level
# Default value for the security level with each session.
# The default is 'impossible'. You may wish to set this to either 'low', 'medium', 'high' or impossible'.
$_DVWA['default_security_level'] = getenv('DEFAULT_SECURITY_LEVEL') ?: 'impossible';

# Default locale
# Default locale for the help page shown with each session.
# The default is 'en'. You may wish to set this to either 'en' or 'zh'.
$_DVWA['default_locale'] = getenv('DEFAULT_LOCALE') ?: 'en';

# Disable authentication
# Some tools don't like working with authentication and passing cookies around
# so this setting lets you turn off authentication.
$_DVWA['disable_authentication'] = getenv('DISABLE_AUTHENTICATION') ?: false;

define('MYSQL', 'mysql');
```

Queste impostazioni permettono a DVWA di sapere dove trovare il database e con quale utente collegarsi.

Per preparare il database ho avviato il servizio MariaDB e sono entrata come root. Ho creato l'utente kali collegato da 127.0.0.

```
(root@kali)-[/home/kali]
# mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 7
Server version: 11.8.8-MariaDB-1 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> create user 'kali'@'127.0.0.1' identified by 'kali' ;
Query OK, 0 rows affected (0.004 sec)

MariaDB [(none)]> grant all privileges on dvwa.* to 'kali'@'127.0.0.1' identified by 'kali' ;
Query OK, 0 rows affected (0.002 sec)

MariaDB [(none)]> 
```

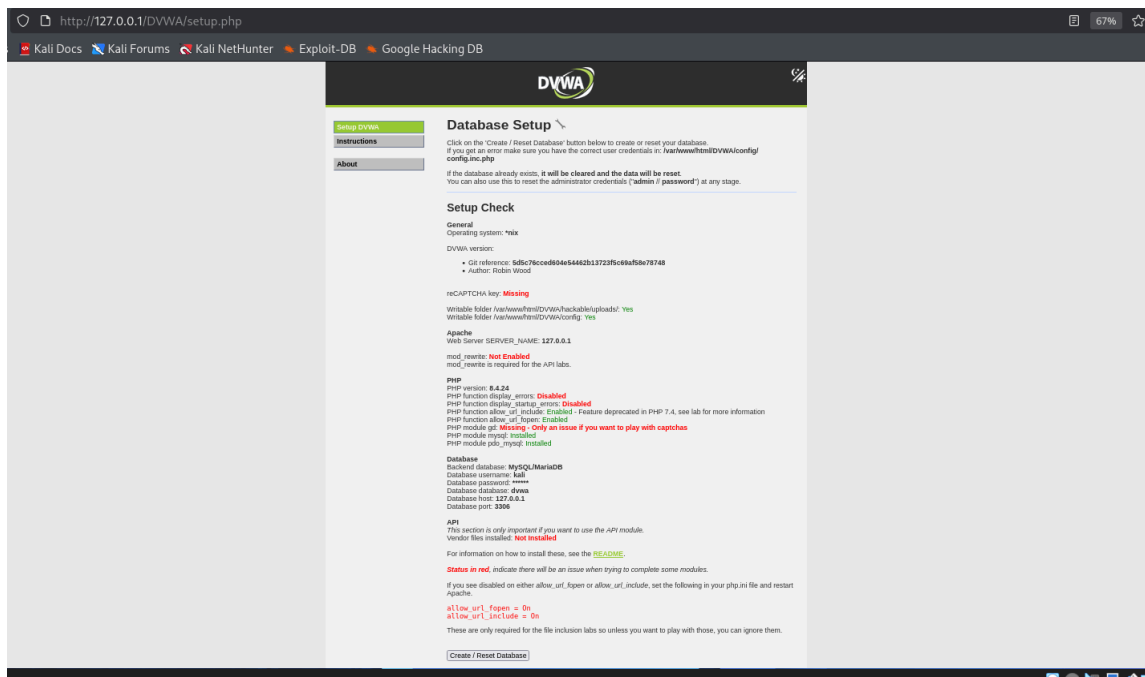
I messaggi Query OK confermano che la creazione dell'utente e l'assegnazione dei privilegi sono andate a buon fine. In questo modo DVWA può collegarsi al proprio database senza usare direttamente l'utente amministratore.

Per completare la configurazione ho aperto il file php.ini della versione PHP presente in Kali, nella cartella /etc/php/8.4/apache2. Ho abilitato allow\_url\_fopen e allow\_url\_include, quindi ho riavviato Apache per applicare le modifiche.

```
; Whether to allow the treatment of URLs (like http:// or ftp://) as files.
; https://php.net/allow-url-fopen
allow_url_fopen = On

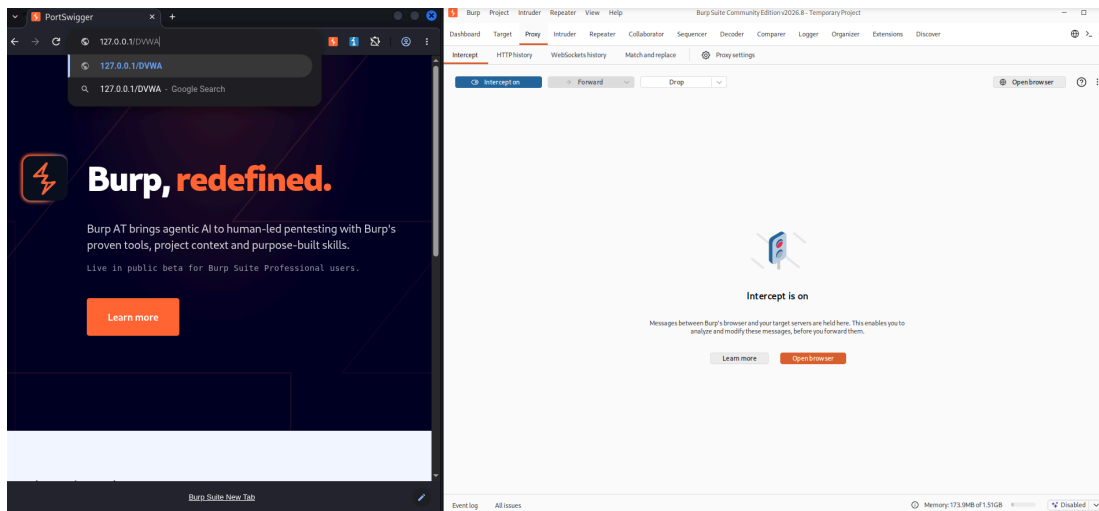
; Whether to allow include/require to open URLs (like https:// or ftp://) as files.
; https://php.net/allow-url-include
allow_url_include = On
```

Ho quindi aperto <http://127.0.0.1/DVWA/setup.php>. La pagina Setup ha mostrato che le cartelle di DVWA sono scrivibili, che il modulo pdo\_mysql è installato e che la configurazione del database punta al servizio locale.

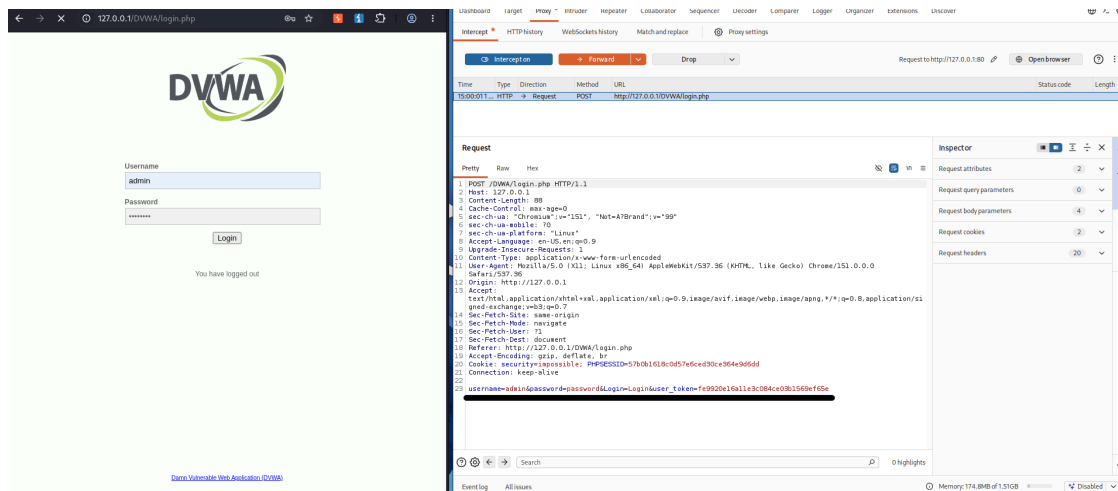


Dopo l'inizializzazione del database, DVWA è risultata disponibile nella VM per le prove successive.

Nella seconda parte ho avviato Burp Suite con un progetto temporaneo. Burp opera come proxy tra browser e applicazione: nel laboratorio permette di vedere la richiesta prima che venga inviata a DVWA.

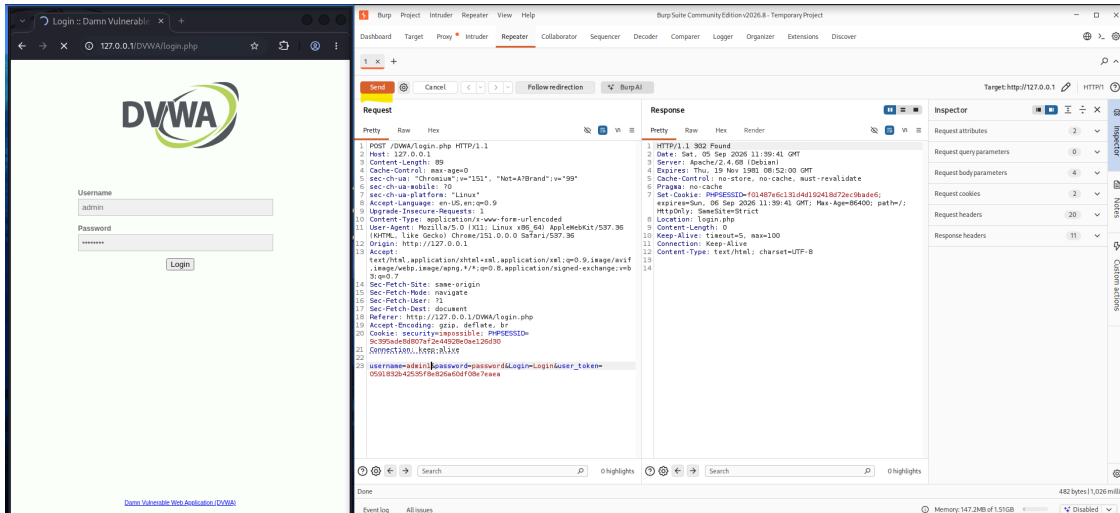


Con Proxy Intercept attivo ho aperto la pagina di login di DVWA tramite il browser di Burp. Ho inserito le credenziali predefinite del laboratorio e ho inviato il modulo. Burp ha registrato una richiesta POST diretta a 127.0.0.1/DVWA/login.php.



Per eseguire una prova controllata ho inviato una copia della richiesta in Burp Repeater. Repeater permette di modificare e rinviare una singola richiesta senza bloccare la normale navigazione nel browser.

Ho cambiato esclusivamente il valore del nome utente da admin ad admin1, mantenendo invariati gli altri campi della richiesta. Il server ha risposto con HTTP 302 Found e con il reindirizzamento alla pagina di login.



La risposta mostra che DVWA ha ricevuto la richiesta modificata ma non ha accettato il login.

In conclusione, l'esercizio è stato completato correttamente. Ho installato e configurato DVWA in Kali Linux, preparato il database MariaDB e il server Apache, verificato i requisiti PHP e usato Burp Suite per intercettare, leggere e modificare in modo autorizzato una richiesta di login nella mia applicazione locale.

L'attività ha mostrato in modo pratico il funzionamento di una richiesta HTTP POST, dei parametri del form, dei cookie di sessione e del token anti CSRF. Ha inoltre evidenziato perché questi controlli e l'uso di HTTPS sono importanti nelle applicazioni web reali.